

MODULE 19 · DOMAIN 4 - DATA SECURITY AND GOVERNANCE

Encryption and masking

AWS KMS, encryption at rest and in transit, cross-account keys, masking, anonymisation and finding personal data.

DOMAIN 4 of 4 EXAM WEIGHT 18% MODULE 19 of 27

Encryption questions are almost never about **whether**. They are about **who holds the key**.

The encryption options for Amazon S3

OPTION	WHO HOLDS AND MANAGES THE KEY
SSE-S3	AWS entirely. Applied by default to every new object
SSE-KMS	A KMS key you control, with an audit trail of every use
DSSE-KMS	Two independent layers with KMS keys. For strict regimes
SSE-C	You supply the key with every request. Disabled by default since April 2026
Client-side	You encrypt before upload. AWS never sees the plaintext

ON THE EXAM

Availability warning: SSE-C is disabled by default on new buckets from 6 April 2026, and must be enabled deliberately.

Why anyone chooses SSE-KMS

- ◆ **A key policy** says which principals may use the key, independently of the bucket.
- ◆ **Every decryption is logged in CloudTrail**, so access to data is auditable.
- ◆ **Revoking key access** makes the data unreadable without touching the objects.
- ◆ **Cross-account decryption** is expressed in the key policy.
- ◆ **KMS charges per request**, which matters at data lake scale.

ON THE EXAM

Two permissions must both hold: permission on the object, and permission to use the key. That is the point of it.

What a KMS key can be

TYPE	CHARACTER
AWS owned	Used by a service across many customers. Invisible to you
AWS managed	One per service per account, created and rotated by AWS
Customer managed	Yours. Key policy, rotation, disable, cross-account
Imported key material	You supply the material. AWS never generates it
External key store	The key stays in your own HSM, outside AWS entirely

ON THE EXAM

The last two exist for regulatory regimes requiring the organisation to hold the material. They add real operational burden.

The cost of encrypting a data lake

- ◆ **KMS is charged per API request**, and every object decryption is a request.
- ◆ **A query reading a million objects** makes a million KMS requests.
- ◆ **S3 Bucket Keys** reduce KMS calls by up to ninety nine percent.
- ◆ A bucket-level key is used to derive per-object keys, so KMS is called far less.
- ◆ **Enable Bucket Keys** on any bucket using SSE-KMS at scale.

ON THE EXAM

Bucket Keys are the answer when SSE-KMS is required and the KMS bill has become noticeable.

AWS managed or customer managed keys?

AWS MANAGED KEY

Created for you

- One per service per account, made automatically
- No key policy to write
- Rotated by AWS every year
- Cannot be shared across accounts

CUSTOMER MANAGED KEY

Yours

- You write the key policy
- Cross-account use, and grants
- Rotation you configure
- Can be disabled or scheduled for deletion

THE TIEBREAKER

Cross-account access and the ability to revoke both require a customer managed key. AWS managed keys cannot do either.

Encryption across account boundaries

- ◆ **Three things must align:** the resource policy, the identity policy, and the key policy.
- ◆ **The key policy is the one people forget,** because encryption is usually invisible.
- ◆ **Replication to another account** needs a key the destination can use.
- ◆ **Multi-Region keys** for cross-Region replication, so the copy is decryptable.
- ◆ **An AWS managed key cannot be shared,** so cross-account work needs a customer managed one.

ON THE EXAM

Skill 4.3.3 names configuring encryption across account boundaries. Three policies, and the third is the usual gap.

A company shares a data lake bucket with a partner account. The bucket policy grants the partner's role read access, and the partner's role has the matching Amazon S3 permissions. Objects are encrypted with SSE-KMS using a customer managed key.

The partner receives an access denied error when reading objects. CloudTrail shows the S3 GetObject call succeeding and a subsequent KMS Decrypt call being denied.

What is missing?

- ☐ A The KMS key policy does not grant the partner's role permission to decrypt
- ☐ B The bucket must be re-encrypted with SSE-S3 for cross-account access to work
- ☐ C The partner needs a copy of the objects in their own account
- ☐ D S3 Bucket Keys must be enabled before cross-account decryption is possible

◆ PAUSE AND DECIDE

What is missing?

- A

 The key policy does not allow the partner to decrypt
CloudTrail says exactly this. GetObject succeeded and Decrypt was denied, so the object permission is right and the key permission is not.
- B

 Re-encrypt with SSE-S3
Would work by removing the key control the company presumably wanted. It solves the symptom by abandoning the requirement.
- C

 Copy the objects to the partner
Duplicates the data and the governance problem, to avoid adding one statement to a key policy.
- D

 Enable Bucket Keys
A cost optimisation reducing KMS calls. It has no bearing on whether a principal may decrypt.

THE SIGNAL

The CloudTrail detail hands you the answer. Two permissions are needed and the trail says which one failed.

Encryption across the services

SERVICE	AT REST
Amazon S3	On by default with SSE-S3. SSE-KMS or DSSE-KMS optional
Amazon Redshift	Cluster-level, with KMS. Chosen at creation for provisioned clusters
AWS Glue	Security configurations encrypt job bookmarks, logs and output
Amazon EMR	Security configurations for at-rest and in-transit, EBS and EMRFS
Kinesis and MSK	Server-side encryption with KMS
Amazon DynamoDB	Always encrypted. AWS owned, AWS managed or customer managed key

ON THE EXAM

Glue and EMR both use a security configuration, a reusable object applied to jobs or clusters. That name is examinable.

Encrypting data on the move

- ◆ **Kinesis Data Streams** encrypts at rest with KMS, per stream.
- ◆ **Producers and consumers need key permission**, not just stream permission.
- ◆ **Amazon MSK** encrypts at rest, and in transit between brokers.
- ◆ **Firehose** encrypts its buffer, and inherits the destination's encryption on delivery.
- ◆ **A stream is a copy of the data.** It needs the same controls as the store.

ON THE EXAM

The second bullet is the streaming version of scenario one. A consumer with stream access and no key access fails.

Encrypting the warehouse and the cluster

- ◆ **Redshift provisioned encryption is chosen at creation.** Changing it means migrating.
- ◆ **Snapshot and restore into an encrypted cluster** is the migration path.
- ◆ **Redshift Serverless is encrypted** by default.
- ◆ **EMR security configurations** cover EBS volumes, EMRFS and local disks separately.
- ◆ **Glue security configurations** cover job bookmarks, CloudWatch logs and S3 output.

ON THE EXAM

Glue job bookmarks contain data about what was processed. They are encrypted separately, and people forget them.

Encryption in transit

- ◆ **TLS on every AWS API endpoint**, so service calls are encrypted already.
- ◆ **Enforce it** with a bucket policy condition refusing insecure transport.
- ◆ **Within an EMR cluster**, node to node traffic needs a security configuration.
- ◆ **Redshift** can require SSL for client connections.
- ◆ **Kafka clients** use TLS, and MSK can require it.

ON THE EXAM

The gap is usually inside a cluster, not on the way to AWS. Node-to-node traffic is not encrypted unless you ask.

Enforcing encryption rather than checking it

- ◆ **A bucket policy condition** can refuse any upload not using the required key.
- ◆ **Refuse requests without TLS** with a secure transport condition.
- ◆ **AWS Config rules** report resources that are not encrypted as required.
- ◆ **Config reports after the fact.** A policy condition prevents it happening.
- ◆ **SCPs** can require encryption across every account in an organisation.

ON THE EXAM

Prevention beats detection. A condition that refuses the write means the unencrypted object never exists.

A regulated company requires that every object in a data lake bucket is encrypted with a specific customer managed KMS key. An audit has found several thousand objects encrypted with SSE-S3, written by a job whose author was unaware of the requirement. The company wants to prevent recurrence, and to be alerted if any resource in the organisation drifts from the encryption standard.

Which combination best meets both needs?

- ☐ A A bucket policy condition refusing uploads that do not specify the required key, plus AWS Config rules reporting non-compliant resources
- ☐ B Enable default encryption on the bucket with the required key
- ☐ C A nightly Lambda function that re-encrypts objects found with the wrong encryption
- ☐ D Enable Amazon Macie to detect the unencrypted objects

◆ PAUSE AND DECIDE

Which combination best meets both needs?

- A** Policy condition to prevent, Config to report
The condition makes a non-compliant write impossible; Config answers the organisation-wide drift requirement.
- B** Default encryption on the bucket
Sets what happens when a request specifies nothing. A request explicitly asking for SSE-S3 still succeeds.
- C** Nightly re-encryption
Fixes objects after they were written wrongly, leaving a window each day, and never prevents anything.
- D** Macie
Finds sensitive data and reports bucket-level security posture. It is not an encryption enforcement mechanism.

THE SIGNAL

Default encryption sets a default. A policy condition sets a rule. The difference decides this question.

You cannot protect personal data you **do not know you have.**

Amazon Macie

- ◆ **Automated sensitive data discovery** samples S3 objects continuously.
- ◆ **Managed data identifiers** for names, addresses, passport and national ID numbers.
- ◆ **Financial and credential detection** too, including keys and tokens in files.
- ◆ **Custom data identifiers** for organisation-specific patterns, with regex and proximity rules.
- ◆ **Allow lists** to exclude known safe matches, such as test data.
- ◆ **A sensitivity score per bucket**, and an interactive map across accounts.

ON THE EXAM

Macie also reports bucket security posture: unencrypted, publicly accessible, or shared outside the organisation.

A dependency worth knowing

- ◆ **Macie cannot read an object** it is not permitted to decrypt.
- ◆ **For SSE-KMS and DSSE-KMS**, the key policy must allow Macie to use the key.
- ◆ **Without it**, Macie reports only metadata and finds nothing inside.
- ◆ **SSE-S3 objects** need no additional permission.
- ◆ **Discovery results expire after ninety days** unless stored in a bucket you configure.

ON THE EXAM

Encryption and discovery interact. A well-encrypted lake can be entirely opaque to the tool meant to inspect it.

A company enabled Amazon Macie across its data lake six months ago. The lake holds around forty terabytes across two hundred buckets, all encrypted with SSE-KMS using several customer managed keys. Macie reports almost no sensitive data findings.

A manual review of one dataset has found unredacted customer email addresses and national identifiers in a free-text notes column.

What is the most likely explanation?

- ☐ A Macie does not inspect free-text columns, only structured fields
- ☐ B Macie lacks permission to use the KMS keys, so it can only report object metadata
- ☐ C Macie only scans buckets smaller than one terabyte
- ☐ D The findings expired, because Macie retains results for ninety days

◆ PAUSE AND DECIDE

What is the most likely explanation?

- A

 Macie ignores free text
The opposite. Free text is where managed data identifiers are most useful, matching patterns wherever they appear.
- B

 No permission to use the KMS keys
Macie can only decrypt SSE-KMS objects if the key policy allows it. Without that it reports metadata and finds nothing.
- C

 A one terabyte bucket limit
Invented. Macie samples intelligently across buckets of any size.
- D

 Findings expired
Detailed discovery results expire after ninety days. Findings themselves would not explain six months of near-silence.

THE SIGNAL

Almost no findings across two hundred encrypted buckets is suspicious. Silence is a symptom, not a clean bill of health.

Encryption protects data from outsiders.
Masking protects it from people who are allowed in.

Encryption or masking?

ENCRYPTION

Against outsiders

- Protects the stored bytes and the wire
- Transparent to anyone authorised
- All or nothing per key
- Does nothing about over-broad access

MASKING

Against insiders

- Changes what an authorised person sees
- Applied per role, per column
- Preserves the record while hiding a field
- Does nothing if the storage is stolen

THE TIEBREAKER

They solve different threats and the exam states which. A support agent seeing too much is never an encryption problem.

The techniques, and what they preserve

TECHNIQUE	EFFECT
Masking	Shows part of a value. The last four digits of a card
Redaction	Removes the value entirely for that audience
Tokenisation	Replaces a value with a token, reversible through a lookup
Hashing	One-way. Equal values still match, so joins still work
Generalisation	Reduces precision. A birth year instead of a birth date
Anonymisation	No route back to the individual, by any means

ON THE EXAM

Hashing keeps joins working while removing the readable value. That is why it is common in analytics.

Where masking happens

- ◆ **In the warehouse.** Redshift dynamic data masking, applied by role.
- ◆ **In the lake.** Lake Formation column grants hide the column entirely.
- ◆ **In the pipeline.** Glue transforms hash or tokenise on the way through.
- ◆ **In the BI tool,** for what a dashboard viewer sees.
- ◆ **At ingestion,** which is the strongest, because the raw value is never stored.

ON THE EXAM

Masking at ingestion means the sensitive value never enters the lake. Everything else protects data you are holding.

Choosing a technique for a requirement

- ◆ **Support needs to recognise a record.** Masking, showing the last four characters.
- ◆ **Analytics needs to join, not to read.** A consistent salted hash.
- ◆ **A value must be recoverable later.** Tokenisation with a controlled lookup.
- ◆ **Nobody should ever see it again.** Redaction or anonymisation.
- ◆ **Ask what the audience needs to do,** not how sensitive the field is.

ON THE EXAM

The requirement is never "protect this column". It is always "let this audience do this much and no more".

Deleting personal data

- ◆ **An erasure request** means finding every copy, which is a lineage question.
- ◆ **Open table formats** make row-level deletion possible, as module nine showed.
- ◆ **Object Lock and erasure conflict.** Locked data cannot be deleted.
- ◆ **Crypto-shredding** deletes the key instead, making the data unreadable.
- ◆ **Separate keys per tenant or subject** make crypto-shredding practical.

ON THE EXAM

Crypto-shredding is the answer when data cannot be rewritten. Destroy the key and the ciphertext is meaningless.

A company must let its support team see customer records for troubleshooting, but the team must never see full national identifiers. The fraud investigation team must see them in full. The data sits in Amazon Redshift, and both teams query the same tables.

Analytics also needs to count distinct customers across datasets without any team seeing the identifier at all.

Which combination meets all three requirements?

- ☐ A Dynamic data masking on the identifier column by role for support and fraud, and a salted hash of the identifier for the analytics join key
- ☐ B Encrypt the identifier column with a KMS key and give the fraud team the key
- ☐ C Create three copies of the table, one per audience
- ☐ D Remove the identifier column entirely and rely on customer name for joins

◆ PAUSE AND DECIDE

Which combination meets all three requirements?

- A

 Masking by role, plus a salted hash for analytics
Masking serves support and fraud from one table; the hash lets analytics count distinct customers with no readable value.
- B

 Column encryption with a key for fraud
Support then sees ciphertext rather than a partial value, and analytics cannot join on it at all.
- C

 Three copies
Three pipelines, three schemas, and the certainty they will disagree. This is what masking exists to avoid.
- D

 Drop the column, join on name
Names are neither unique nor stable, and a name is personal data too. It fails on correctness and on privacy.

THE SIGNAL

Three audiences, three different needs from one column. Masking and hashing answer different halves.

Managing keys over time

- ◆ **Automatic rotation** creates new key material annually, keeping the old for decryption.
- ◆ **Objects are not re-encrypted.** Old data still decrypts with the old material.
- ◆ **Key policies and grants** control use, and grants can be revoked individually.
- ◆ **Deleting a key is irreversible**, with a mandatory waiting period first.
- ◆ **Multi-Region keys** for data replicated across Regions.

ON THE EXAM

Rotation changes the key material, not the key. Nothing needs re-encrypting and nothing breaks.

When a key becomes a dependency

- ◆ **Disabling a key** makes every object encrypted with it unreadable immediately.
- ◆ **Deleting a key** is permanent, after a waiting period of seven to thirty days.
- ◆ **That permanence is the point** when crypto-shredding, and a hazard otherwise.
- ◆ **KMS has request quotas**, which a large parallel job can reach.
- ◆ **Bucket Keys reduce that pressure** as well as the cost.

ON THE EXAM

A key is a single point of failure for everything encrypted with it. That is both the control and the risk.

Protecting data in logs and results

- ◆ **Logs leak personal data** when applications log request payloads.
- ◆ **CloudWatch Logs data protection** masks sensitive patterns at ingestion.
- ◆ **Athena query results** contain whatever the query returned, in a bucket.
- ◆ **Encrypt results and restrict the location**, per workgroup.
- ◆ **Redshift and EMR logs** can be encrypted through their security configurations.

ON THE EXAM

Every derived artefact inherits the sensitivity of its source. Logs, results and exports are all copies.

Knowing the estate is actually protected

- ◆ **Macie reports bucket posture** across accounts, not only sensitive data.
- ◆ **AWS Config rules** evaluate resources against encryption requirements continuously.
- ◆ **Security Hub** aggregates findings from both into one view.
- ◆ **Alert on new unencrypted resources**, rather than discovering them at audit.
- ◆ **A one-off audit** describes the estate on the day somebody looked.

ON THE EXAM

Continuous evaluation is the difference between knowing your posture and knowing what it was last quarter.

Symptoms and their causes

SYMPTOM	LIKELY CAUSE
Cross-account read fails on encrypted objects	The KMS key policy does not allow the other account
The KMS bill grows with query volume	No S3 Bucket Keys. Every object read calls KMS
Macie finds nothing in an encrypted lake	Macie has no permission to use the KMS keys
Objects still written with the wrong encryption	Default encryption set, but no policy condition enforcing it
Data cannot be shared to another Region	A single-Region key. Use a multi-Region key
Sensitive data appears in query results	Result location not restricted or encrypted

ON THE EXAM

The fourth row is the default-against-condition distinction, which decides the second worked scenario.

Reading an encryption question quickly

- ◆ **Who needs to hold the key?** Cross-account or revocable means customer managed.
- ◆ **Prevent or detect?** A policy condition prevents; Config and Macie report.
- ◆ **At rest or in transit?** In transit usually means inside a cluster.
- ◆ **Outsiders or insiders?** Encryption for the first, masking for the second.
- ◆ **Does a join still need to work?** That points at hashing rather than redaction.

ON THE EXAM

Next: governance, data sharing and SageMaker Catalog. The last teaching module in Domain 4.